

Cybersecurity Daily Newsletter

Vol. 002 | 2026-06-14 07:00 WIB

Top 5 Highlights

- NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks
- Critical Splunk Enterprise Flaw Lets Attackers Run Code Without Authentication
- CVE-2026-5513 | ladela Online Scheduling and Appointment Booking System Plugin setting cross site scripting (EUVD-2026-36651)
- CVE-2026-9061 | Store Locator Plugin up to 1.6.8 on WordPress cross site scripting (EUVD-2026-36643)
- CVE-2026-9629 | codesupplyco Canvas Plugin up to 2.5.2 on WordPress day cross site scripting (EUVD-2026-36648)

Threat Intelligence (10)

01. NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks

By default, npm install will no longer execute scripts from dependencies, unless explicitly allowed. The post NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.securityweek.com/npm-12-will-change-script-execution-behavior-to-prevent-supply-chain-attacks/>

02. [+24h Old] China-nexus group hid in Linux login system for nearly a decade

The group's operation, dubbed Operation Highland, involved backdooring the Pluggable Authentication Modules (PAM) and OpenSSH components, which are fundamental to user authentication on Linux systems.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/china-nexus-group-hid-in-linux-login-system-for-nearly-a-decade>

03. [+24h Old] Over 400 Arch Linux AUR Packages Hijacked to Deploy Infostealer and eBPF Rootkit

Attackers took over more than 400 packages in the Arch User Repository (AUR) this week and rewrote their build scripts to install a credential stealer on any machine that built them. The malware is a Rust binary built to harvest developer secrets. When it lands with root, it can also load an eBPF rootkit to hide itself. The AUR is Arch Linux's community pac...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/over-400-arch-linux-aur-packages.html>

04. [+24h Old] China-Linked Hackers Backdoored Linux Login Software to Hide for Nearly a Decade

Instead of hiding on the laptops and servers defenders watch most closely, a China-nexus group spent close to a decade hidden inside the Linux login system itself. Sygnia, which tracks the group as Velvet Ant, says it backdoored the PAM and OpenSSH components that decide who is allowed to sign in, planting its access where ordinary cleanup could not

reach i...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/china-linked-hackers-backdoored-linux.html>

05. [+24h Old] Over 400 Arch Linux packages compromised to push rootkit, infostealer

More than 400 packages in the Arch User Repository (AUR) are distributing a Linux rootkit and infostealer malware targeting credentials and access tokens. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/over-400-arch-linux-packages-compromised-to-push-rootkit-infostealer/>

06. [+24h Old] Warrantless wiretaps cut off for a week following US Congress vote

Lawmakers have failed to extend a surveillance law that allows US intelligence agencies to monitor targets abroad without a warrant. Congress rejected a vote to extend Section 702 of the Foreign Intelligence Surveillance Act to July 2, which means, for a few days at least, some surveillance will be put on hold, for the first time since the Act was passed in...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.csoonline.com/article/4184603/warrantless-wiretaps-cut-off-for-a-week-following-u-s-congress-vote.html>

07. [+24h Old] The Good, the Bad and the Ugly in Cybersecurity - Week 24

Authorities seize crypto-laundering network and fake recruitment sites, JDY botnet targets U.S. military, and Miasma worm infects Microsoft and PyPi repos.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-24-7/>

08. [+24h Old] GitHub to Update npm to Thwart Software Supply Chain Attacks

NPM, part of GitHub, announced a new version of the npm package manager with several security improvements, including disabling install scripts

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.infosecurity-magazine.com/news/github-update-npm-supply-chain/>

09. [+24h Old] ISC Stormcast For Friday, June 12th, 2026

<https://isc.sans.edu/podcastdetail/9970>, (Fri, Jun 12th)

ISC Stormcast For Friday, June 12th, 2026 <https://isc.sans.edu/podcastdetail/9970>, (Fri, Jun 12th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33074>

10. [+24h Old] Rethinking MDR as Attackers and Defenders Embrace AI

For most of the past decade, managed detection and response was the answer to a real problem. Security teams couldn't staff around the clock, couldn't hire enough analysts, and needed someone else to handle the alert queue. MDR stepped in. It worked well enough. Until now. The threat landscape has changed faster than the MDR model can adapt. Attackers are u...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/rethinking-mdr-as-attackers-and.html>

Latest Vulnerabilities (10)

01. Critical Splunk Enterprise Flaw Lets Attackers Run Code Without Authentication

Splunk has released security updates to address a critical security flaw in Splunk Enterprise that could be exploited to conduct unauthenticated file operations and even remote code execution. The vulnerability, tracked as CVE-2026-20253, is rated 9.8 on the CVSS scoring system. "In Splunk Enterprise versions below 10.2.4 and 10.0.7, an unauthenticated user...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/06/critical-splunk-enterprise-flaw-lets.html>

02. CVE-2026-5513 | Iadela Online Scheduling and Appointment Booking System Plugin setting cross site scripting (EUVD-2026-36651)

A vulnerability categorized as problematic has been discovered in Iadela Online Scheduling and Appointment Booking System Plugin up to 27.2 on WordPress. Impacted is an unknown function of the component setting Handler . Such manipulation leads to cross site scripting. This vulnerability is documented as CVE-2026-5513...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370827>

03. CVE-2026-9061 | Store Locator Plugin up to 1.6.8 on WordPress cross site scripting (EUVD-2026-36643)

A vulnerability was found in Store Locator Plugin up to 1.6.8 on WordPress. It has been rated as problematic . This issue affects some unknown processing. This manipulation causes cross site scripting. This vulnerability is registered as CVE-2026-9061...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370826>

04. CVE-2026-9629 | codesupplyco Canvas Plugin up to 2.5.2 on WordPress day cross site scripting (EUVD-2026-36648)

A vulnerability was found in codesupplyco Canvas Plugin up to 2.5.2 on WordPress. It has been declared as problematic . This vulnerability affects unknown code. The manipulation of the argument day results in cross site scripting. This vulnerability is cataloged as CVE-2026-9629...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370825>

05. CVE-2026-3297 | Softaculous Page Builder Plugin up to 2.0.9 on WordPress cross site scripting (EUVD-2026-36646)

A vulnerability was found in Softaculous Page Builder Plugin up to 2.0.9 on WordPress. It has been classified as problematic . This affects an unknown part. The manipulation leads to cross site scripting. This vulnerability is listed as CVE-2026-3297 . The attack may be initiated remotely. There is no available exploit.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370824>

06. CVE-2026-11624 | Google MCP Toolbox for Databases up to 0.24.x origin validation (Issue 3113 / EUVD-2026-36650)

A vulnerability was found in Google MCP Toolbox for Databases up to 0.24.x and classified as critical . Affected by this issue is some unknown functionality. Executing a manipulation can lead to origin validation error. This vulnerability is tracked as CVE-2026-11624...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370823>

07. CVE-2026-9134 | fooplugins Photo Gallery by FooGallery Plugin up to 3.1.31 on WordPress Shortcode foogallery_sanitize_javascript cross site scripting (EUVD-2026-36645)

A vulnerability has been found in fooplugins Photo Gallery by FooGallery Plugin up to 3.1.31 on WordPress and classified as problematic . Affected by this vulnerability is the function foogallery_sanitize_javascript of the component Shortcode Handler...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370822>

08. CVE-2026-9109 | john-dagelmore GPTranslate Plugin up to 2.31 on WordPress Deterministically Derived API Key request gptApiKey cross site scripting (EUVD-2026-36642)

A vulnerability, which was classified as problematic , was found in john-dagelmore GPTranslate Plugin up to 2.31 on WordPress. Affected is an unknown function of the file /wp-json/gptranslate/v1/request of the component Deterministically Derived API Key Handler...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370821>

09. CVE-2026-1291 | tigroumeow Meow Gallery Plugin up to 5.4.4 on WordPress REST API Endpoint authorization (EUVD-2026-36649)

A vulnerability, which was classified as critical , has been found in tigroumeow Meow Gallery Plugin up to 5.4.4 on WordPress. This impacts an unknown function of the component REST API Endpoint . This manipulation causes authorization bypass. The identification of this vulnerability is CVE-2026-1291...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370820>

10. CVE-2026-9062 | Store Locator WordPress Plugin up to 1.6.8 on WordPress information disclosure (EUVD-2026-36644)

A vulnerability classified as problematic was found in Store Locator WordPress Plugin up to 1.6.8 on WordPress. This affects an unknown function. The manipulation results in information disclosure. This vulnerability was named CVE-2026-9062 . The attack may be performed from remote. There is no available exploit. Upgrading the affected component is advised.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370819>

Data Breach & Cybercrime (10)

01. [+24h Old] Novo Nordisk discloses data breach affecting patient and healthcare professional information

Attackers gained access to Novo Nordisk's internal IT systems, copying non-public data without authorization.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/novo-nordisk-discloses-data-breach-affecting-patient-and-health-care-professional-information>

02. [+24h Old] Maine disables data breach notification portal after fake disclosures

Maine has taken its public data breach reporting portal offline after fraudulent breach disclosures were published on the state's website, prompting a review of procedures to prevent abuse in the future. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/maine-disables-data-breach-notification-portal-after-fake-disclosures/>

03. [+24h Old] Google Sues Chinese Smishing Network Accused of Using Gemini AI in Phishing

Google on Friday said it's pursuing legal action against a Chinese cybercrime network, accusing it of using its Gemini artificial intelligence (AI) agent to send phishing text messages targeting Americans. The network is said to be behind the development and management of a phishing-as-a-service (PhaaS) software kit called Outsider, per the tech giant. "The...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/06/google-sues-chinese-smishing-network.html>

04. [+24h Old] Ukrainian national pleads guilty to role in Conti ransomware operation

A Ukrainian national extradited from Ireland to the United States last year has pleaded guilty to conspiracy charges tied to the Conti ransomware operation. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/ukrainian-national-pleads-guilty-to-role-in-conti-ransomware-operation/>

05. [+24h Old] French government's secure messaging system breached

An intruder has breached the French government's encrypted messaging service, Tchap, showing once again that human error is a weak spot in any security system. Tchap was developed in France as an example of national sovereignty and was designed to be a more secure option than WhatsApp for communication between government employees. In this case, it wasn't t...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoononline.com/article/4184576/french-governments-secure-messaging-system-breached.html>

06. [+24h Old] Stolen iPhones could soon be worth a lot less to thieves

Apple and the Met Police are working together to make stolen iPhones harder to reset, resell, and profit from.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/mobile/2026/06/stolen-iphones-could-soon-be-worth-a-lot-less-to-thieves>

07. [+24h Old] Early Warning Signs of Supply-Chain Attacks Live in the Dark Web

GitHub access sales, leaked repositories, and stolen API keys can all become supply-chain attack footholds. Flare explores how underground forums expose early signals tied to software supply-chain risk. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/early-warning-signs-of-supply-chain-attacks-live-in-the-dark-web/>

08. [+24h Old] Ransomware Payment Crypto Laundering Platform Taken Out by FBI and Europol

Domain of dark web money laundering platform AudiA6 seized and suspects arrested in joint operation by the FBI, Europol and others

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/ransomware-crypto-laundering/>

09. [+24h Old] Novo Nordisk reports cyberattack as UK gives Wegovy pill the nod

Clinical trial participant data stolen, but pharma giant says exposed records were pseudonymized

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/06/12/novo-nordisk-says-hackers-stole-clinical-trial-data/5254812>

10. [+24h Old] Google sues China-based scammers over Gemini AI abuse

Google has filed a lawsuit against Outsider Enterprise, a China-based cybercrime network for using AI tools, including Gemini, to build phishing websites and scam infrastructure. The company said the operation has affected “hundreds of thousands of victims,” with losses estimated in the millions of dollars. It also links the group to more than 9,000 fake we...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/06/12/google-china-based-cybercrime-network-lawsuit/>